

Poonawalla Fincorp Limited

Cyber Security Policy

Effective Date: 25.10.2024

Approval Date: 25.10.2024

Version No.: 11.0

Approved By: Board of Directors

Policy Owner: Information Security
team

This document is Internal in nature and supersedes any existing Policy on Cyber security policy in the Company and should be read in conjunction with the most recent policies and procedures documented.

CYBER SECURITY POLICY

Document review and approval

Document Control

Document Name	Cyber Security Policy
Documen	11.0
Frequency of review	Yearly
Effective Date	25.10.2024
Approved by	Board of Directors
Policy Owner	Information Security Team
Approved by	Board of Directors
Reviewed by	Chief Information Security Officer

Version Control

Date	Version	Change Description (in brief)
27 th -OCT-21	7.0	To align with the regulatory requirements
21 st -OCT-22	8.0	- Updated the SaaS vendor responsibility in Cryptographic Control - Added Risk Acceptance Form
20 th -OCT-23	9.0	Minor Document Update
18 th -JAN-24	10.0	Document update as per new RBI IT governance, Risk and assurance direction
25 th -OCT-24	11.0	Updation of security vulnerability management controls.
17 th -OCT-25	11.0	Annual Review- no changes suggested

Table of Contents

Introduction.....	5
1. Overview:.....	5
2. Purpose:	5
3. Objective:	5
4. Cyber resilience framework:	6
5. Cyber Resilience Framework elements	6
6. Compliance with the Cyber Security Policy:.....	6
7. Review of the Cyber Security Policy:	7
8. Cryptographic Controls:.....	7
9. Log Management & Monitoring.....	8
10. Patch management	8
11. User awareness program	8
12. Defense in depth approach	9
13. Data Leak prevention strategy	9
14. Cyber Security Training and awareness:	9
15. Cyber Crisis Management Plan.....	9
16. Cyber security preparedness indicators:.....	16
17. Mobile Financial Services:	17
18. Continuous Surveillance	18
19. Social Media:.....	19
20. Security Vulnerability Management:.....	19
21. Sharing of information on cyber-security incidents with RBI/ Cert-In.....	20
Annexure(s).....	21

Introduction

1. Overview:

The Cyber Security Policy defines appropriate responsibilities, authority and relationships to manage Cybersecurity in Poonawalla Fincorp Limited and all its group/associate /joint venture companies and subsidiaries (hereafter referred to as 'PFL' in this document).

Organisation's is a trusted custodian of information related to its employees, customers and third parties. Being a NBFC, Organisations' IT Assets and data shall invariably get exposed to the Internet and hence are prone to cyber risks. Hence appropriate Cyber Security Objectives shall be defined and implemented to protect Organisations' Information Assets against applicable Cyber Risks.

The Cyber Security Policy establishes a security management framework for implementation within PFL. Hence, the program must be consistently implemented across PFL.

2. Purpose:

The varied challenges presented by cyber risk should be met with a broad response. Appropriately high-level management's attention is a necessity, as is an effective governance structure able to identify, protect, detect, respond to, recover from, test, learn and be aware of Cybersecurity incidents.

To provide guidelines for addressing cybersecurity and related risks and the mitigation of such risks.

3. Objective:

The objectives of the Cyber Security policy are:

- Prevent occurrence and recurrence of cyber incidents by implementing security proactive/ protective measures.
- Create infrastructure for conformity assessment and certification of compliance to cybersecurity best practices, standards and guidelines.
- Create mechanisms for security threat early warning, vulnerability management and response to security threats.
- Create processes, structures and mechanisms to generate necessary situational scenarios of existing and potential cybersecurity threats and enable timely information sharing for proactive, preventive and protective actions.
- Promote and launch a comprehensive awareness program on information and cybersecurity.

4. Cyber resilience framework:

A cyber resilience framework, or cybersecurity framework, is a crucial component of modern-day business. Cyber resilience is the measure of an enterprise's ability to continue with working as normal while it attempts to prevent, detect, control and recover from threats against its data and IT infrastructure.

5. Cyber Resilience Framework elements.

The standard cyber resilience framework is made up of five key pillars:

- **Prepare against Cyber-attacks by**
 - a. Identifying Critical IT infrastructure
 - b. Identifying critical application threats
 - c. Subscribing to Threat Intelligence feeds.
- **Prevent Cyber-attacks by**
 - a. Collecting and analysing intelligence obtained from Threat Intelligence feeds and taking proactive actions
 - b. Harden / patch critical IT Infrastructure
 - c. Harden / patch critical application vulnerabilities.
- **Detect Cyber-attacks by**
 - a. Having the tools and processes in place to analyse logs
 - b. Implementing co-relation rules for identified use cases to trigger alerts.
- **Respond to Cyber-attacks by**
 - a. a. Having a robust Information Security Incident Response plan in place.
 - b. b. Following the defined Cyber Response plan.
- **Recover from Cyber-attacks by**
 - a. Recover the impacted IT Infrastructure to pre attack state
 - b. Update the management about the attack, the response and the impact.

6. Compliance with the Cyber Security Policy:

The Policy applies to all employees, contractors and third-party vendors who have access to PFL information resources hereinafter referred to as "Users". Any non-compliance to the policy would lead to disciplinary

action including termination with the possibility of legal action being initiated against the individual(s) concerned as applicable by the relevant legislation.

7. Review of the Cyber Security Policy:

The Cyber Security policy shall be reviewed on an annual basis or as and when significant changes occur.

8. Cryptographic Controls:

Objective: To protect the confidentiality, authenticity or integrity of information by cryptographic means.

Policy on the Use of Cryptographic Controls

- a. Encryption shall be adopted for information assets based on the criticality of the information. Standard encryption technology shall be deployed for encryption unless required by regulatory requirements.
- b. PFL shall ensure the protection of sensitive data through:
 - Encryption of sensitive data stored on all backup devices such as cloud storage, tapes, hard disks.
 - Encryption of sensitive data during transit.
- c. Users shall not employ encryption, digital signatures, or digital certificates for any business activity or business information without the written authorisation of the relevant Functional Head and Information Security department, the completion of proper training and having their systems configured by authorised personnel.
- d. Public Key Infrastructure (PKI): PFL should increase the usage of PKI to ensure confidentiality of data, access control, data integrity, authentication and nonrepudiation.

Common use cases for PKI include, but are not limited to:

- Securing web pages
- Encrypting files
- Authenticating and encrypting email messages using S/MIME
- Authenticating connections to sites and services containing corporate data using TLS mutual authentication

Private PKI allows you to issue your private SSL certificates of a unique intermediate root often maintained by a publicly trusted CA. SSL certificates have expiration dates hardcoded into them. When they expire, web browsers will warn their users about your website. The reason SSL certificates

expire is to keep your encryption up to date. PKI SSL certificate should be renewed before expiration. For SaaS based applications, SSL certificate shall be managed by SaaS vendors.

9. Log Management & Monitoring

- All Internet and public facing information assets including devices and applications shall have event logs enabled.
- Processes shall be established to carry out ongoing analysis of event log for all security devices & critical applications managed by PFL.
- Event logs shall be consolidated, classified filtered and analyzed on ongoing basis through implementation of Log and Event Management tool.
- Correlation rules based on identified use cases shall be used for identifying anomalies.
- Audit trails and logs collected shall be analyzed at regular basis to detect patterns and presence of any advanced persistent threats which may result in denial of service.
- A device and application mapping shall be made available to understand the business process workflow which will be helpful to carry analysis and investigation.
- Events identified as suspicious shall be reported and investigated through the Information Security Incident Management Process.
- System Audit logs shall be retained for the period of at least 90 days.

10. Patch management

Continuous monitoring of release of patches by various vendors, advisories issued by Regulatory, CERT-In, and other similar agencies shall be done. Applicable patches shall be identified, tested and applied as per the patch management process.

Patches released against well-known / high risk / reported attacks shall be prioritized. For patches that cannot be implemented, RAF (Risk Acceptance Form) shall be documented and signed-off by CIO/CTO (Chief Technology Officer) and Chief Risk Officer (CRO).

11. User awareness program

Cyber Security is a specialized activity which includes protecting Organizations' information & information systems with procedural and technological security to real-time protection and incident response. Training and awareness programs shall be scheduled for organization's employees in this regard.

In order to train security professionals with appropriate skill sets, appropriate skill training & certifications shall be identified and imparted / obtained.

Third Parties and customers to make them aware of their roles and responsibilities in protecting against Cyber Risks.

12. Defense in depth approach

PFL shall deploy a multilayered defense in depth security protection approach to detect and prevent volumetric attacks impacting performance, consumption of bandwidth and thus leading denial of services.

PFL shall implement adequate environmental security control should for monitoring of breaches / compromises of environmental controls relating to temperature, water, smoke, access alarms, and service availability alerts (power supply, telecommunication, and servers), access logs, etc.

13. Data Leak prevention strategy

Comprehensive data loss/leakage prevention strategy shall be developed to safeguard sensitive (including confidential) business and customer data/information.

This shall include protecting data processed in

- End point devices
- Data in transmission
- Data stored in servers and
- Other digital stores, whether online or offline
- Similar arrangements need to be ensured at the vendor managed facilities as well
- Email Server

14. Cyber Security Training and awareness:

Cyber-security awareness among stakeholders / Top Management / Board

PFL shall proactively promote, among its customers, vendors, service providers and other relevant stakeholders an understanding of their cyber resilience objectives and require and ensure the appropriate action to support their synchronised implementation and testing.

15. Cyber Crisis Management Plan

15.1 Introduction

- A Cyber Crisis Management Plan ensures the preparedness to manage business interruptions in order to provide continuity of services at a minimum acceptable level and to safeguard the financial and competitive position of PFL.

- The objective of a Cyber Crisis Management Plan (CCMP) is to enable PFL to recover or maintain its activities in the event of a cyber-crisis affecting normal business operations.
- The purpose of this Plan is to define a framework for the identification, management and mitigation of a cyber-crisis within the organization.

15.2 Scope

- This Cyber Crisis Management Plan (CCMP) includes guidance, initial actions and procedures to respond to Cyber Crisis.
- This document addresses only incidents that are computer security related, not those caused by natural disasters or power failures. This document is not intended to replace business continuity or disaster recovery planning. It is not intended to be used as a detailed list to accomplish every task associated with cyber crisis, handling and response. Rather, the document is intended to provide framework and processes by which consistent approaches can be developed and resource allocation can be made for a given scenario to facilitate the detection, identification, containment, eradication, and recovery from Cyber Crisis.

15.3 Cyber Crisis Management Team (CCMT)

CCMT shall act as a central point for monitoring to provide oversight for Cyber Crisis management and governance. The Cyber Crisis Management Team will have following members:

- Head of Risk/CRO
- CTO/CIO
- Head – Information Security
- Head Operations
- Head Legal and Compliance
- Head HR
- Head Corporate Communication
- Concerned Business Heads

15.4 Cyber Crisis Criteria

1. Potential cyber crisis shall be escalated as confirmed cyber crisis based on following criteria.
 1. An enterprise-wide cyber-attack involving significant breakdown of supplies or services essential to carry out the mission critical activities across the organization (Example: non-availability of services for >24 hours).
 2. A targeted cyber-attack damaging brand image, public and customer confidence.

15.5 Cyber Crisis Management Procedure



15.6 Detection

15.6.1 Detection of security incident and identification potential cyber crisis

2. SOC analyst will analyze the identified security events monitored by SOC and reported through various sources to detect security incidents based on criteria defined in Information and incident management procedure.
3. SOC analyst will perform initial assessment of detected security incidents to identify potential cyber crisis based on cyber crisis criteria.
4. SOC analyst will immediately inform the Information Security Team, CTO and CIO about potential cyber crisis.

15.6.2 Detection and Declaration of Cyber Crisis

5. Information Security team along with CTO, CIO, IT application team, IT infrastructure team and other relevant stakeholder shall evaluate potential cyber crisis.
6. Assess the situation to identify impact and affected systems to confirm cyber crisis based on cyber crisis criteria.
7. CTO and CIO will decide whether 'Cyber Crisis' needs to be declared after urgent discussion with necessary stakeholders.

15.6.3 Respond, Containment and Recovery

Following steps to be performed

8. Once cyber crisis is declared, Cyber Crisis Management Team (CCMT) will be advised immediately.
9. Information Security team along with CTO, CIO, IT application team, IT infrastructure team will analyze the cyber crisis to identify possible cause and determine possible containment, eradication and recovery actions.
10. Thereafter, the CCMP shall perform determined actions to first containment of the crisis and then to eradication and/or recover from crisis.
11. Possible investigation and analysis actions:
 1. The respective teams involved with crisis handling should investigate and diagnose what has gone wrong.
 2. Examine log files and other data to determine & collect related intelligence details such as how and when the attack occurred, source of attack, volume, attacker details, no. of users \ customers impacted etc. depending on the type of attack.
 3. Engage with respective team to understand other specifics about the crisis.

4. Check all system logs to determine if other malicious activities are involved with the current attack.
5. Engage with Forensics Services partner for investigation as needed.
6. Adequate data to ensure that event analysis can be completed without any hindrance should be captured as part of the logs.
7. All investigations and diagnosis are fully documented and maintain the complete historical record of crisis.

12. Possible containment actions:

1. To limit scope, magnitude and prevent further damage
2. Isolate network segments impacted
3. Perform system backups before reimaging to preserve evidence for forensics and investigations
4. Gather evidence and artifacts
5. Consider guidelines for preservation of evidence mentioned in forensics section.

13. Possible eradication actions:

1. Ensure possible containment actions are performed, and malware is removed
2. Disabling breached account, changing passwords of breached user accounts, unauthorized access
3. Identifying and mitigating all vulnerabilities and security gaps that were exploited.

14. Possible recovery actions:

1. Restore of the system(s) in order to return to normal operation
2. Take remediation steps to clean malicious artefacts in order to return to normal operation.
3. Restore from backup in order to return to normal operation
4. Rebuild the system(s) or environment from zero in order to return to normal operation
5. Invoke BCP/ DR plan to return to normal operation

15.6.4 Communication

Good communication is essential when dealing with a confirmed cyber crisis to help limit confusion, increase responsiveness and transparency. Communication occurs throughout the crisis response phases that involves initial reporting to relevant authorities as well as ongoing communications with those impacted.

Guidelines for composing and creating communication plans:

1. Collect information on the situation, its background, the possible consequences, how it is being handled.
2. Describe what happened and what is happening. Give full details which shall be helpful in assessing the situation.
3. Select relevant, reliable communication channels (external interfaces) and internal interfaces (Notice boards, Public Address system (PA), Television displays etc.).
4. Execute the plan: Inform key interested parties, deliver information to internal audiences and media, employees by choosing appropriate mediums for dissemination.
5. Respond to enquiries and update the information when necessary
6. Maintain a calm and composed outlook toward the cyber crisis to avoid creating panic.

What to communicate	Responsibility
Advise Cyber Crisis Management Team (CCMT) once cyber crisis is declared	CIO/CTO and Head Information Security
Periodic updates on Cyber Crisis to CCMT	Incident management team / Information security team
Reporting of cyber crisis to RBI / Regulatory Body	Legal & Compliance Team / Information security function / CIO /CTO
Forensics Services Partner	Information security function / CISO
Consult with the CCMT members on understanding the crisis and preparing an appropriate response for customers, external parties, media and stakeholders– if required	Head Corporate Communication
Update to employees on the current situation and appropriate steps to be taken by them	Head HR
Law Enforcement Agencies	Legal & Compliance
Seek external legal and/or professional advice if required	Legal & Compliance

15.7 Forensics and Root cause analysis and Preventive Measures

7. Conduct forensics and root cause analysis.
8. Engage with Forensics Services partner for investigation as needed.
9. Based on root-cause analysis, identify preventive measures and implement them to prevent reoccurrence of crisis.
10. Consider the following guidelines for preservation of evidence.
 - Every evidence will be preserved on an as is basis, to ensure its integrity.
 - Any actions that may suggest tampering of evidence will be avoided.
 - Every action (including symptoms of the problem) pertaining to the evidence will be thoroughly and unambiguously documented. This ensures that the scope for challenging the data, by resorting to multiple interpretations, is reduced.
 - Access to the evidence should be strictly controlled. This is important in order to substantiate the claim that the logs are tamper-proof.
 - Before shutting down the system containing the evidence, all data with respect to messages on the screen, memory contents, state of network connections, state of running processes will be noted
 - The following mistakes are to be avoided when handling evidence –.
 - Altering time and date stamps on evidence systems before recording them.
 - Terminating rogue processes.

- Patching the system before investigators respond.
- Not recording the commands executed on the system.
- Using untrusted commands and binaries.
- Writing over potential evidence by installing software on the hard drive.

15.8 Post Crisis

The following things follow recovery from a crisis and should be taken seriously:

1. Declaration of 'Crisis Closure' and advising authorities.
2. Incident management team along with security and respective teams to update and distribute final crisis report to relevant stakeholders.
3. Documenting the learnings from the entire episode and strengthen security posture of organization.

15.9 Examples of activities in common attack scenarios

Following are examples of common attack scenarios which may not necessarily lead to cyber crisis by itself.	
1.Website defacement	
Symptoms /Alerts	Possible Actions
1. A website is completely taken down and replaced by something new. 2. Unauthorized changes made to the appearance of an entire site.	4. Disconnect the Web Server hosting defaced /compromised website. 5. Examine the compromised system /website for specific unauthorized changes. 6. Restore the website content, Shift and run website from a different trusted system by making appropriate DNS changes at the new system 7. Collect relevant logs of server and application.
2. DOS and DDoS Attack	
Symptoms /Alerts	Possible Actions
1. Non-availability of services due to overwhelming malicious network traffic on internet links. 2. System crashes due to overwhelming utilization of computing resources	8. Apply appropriate rate limiting strategies at the local perimeter and mitigation at ISP. 9. Identify the type of attack such as flooding of particular types of packets/requests (TCP SYN, ICMP etc) by examining logs of Router/IPS/IDS/ Firewall. 10. Check Router configuration and implement Egress and Ingress filtering to block spoofed packets by checking reputation of the IPs. 11. Use appropriate DoS and DDoS prevention tools / services. 12. Disable the non-essential ports/services. 13. If problem persists, shift web/mail services hosting to alternate Internet Protocol addresses (IPs).
3.DNS Cache Poisoning Attacks	
Symptoms /Alerts	Possible Actions
1. Redirection of legitimate web/mail traffic to suspicious websites/mail servers	14. Purge cache 15. Restart DNS server 16. Replace DNS records with content from trusted backup

	17. Examine DNS forwarding traffic to identify rogue DNS server and block. 18. Restrict rights of configuration changes to Administrator only. 19. At client side, delete any additional entries in HOSTS file. 20. Use appropriate DNS attack monitoring / prevention tools / services.
4.Application-Level attacks	
Symptoms /Alerts	Possible Actions
1. Unauthorized changes to data, elevation to privilege account, suspicious user activities, presence of malicious links/content due to exploitation of application vulnerabilities	21. Perform analysis of IDS/IPS/WAF/SIEM/Servers/Application logs to identify cause. 22. Disable suspected user accounts 23. Reduce the interactive features and run with minimum essential features 24. Restore data from trusted backup 25. Identify attack sources from application logs and block 26. Enforce Input validation 27. Apply latest patches/updates to mitigate application vulnerabilities 28. Use appropriate web application attack monitoring / prevention tools / services such as web application firewall, web application security assessment services etc.
5. Advanced malwares and persistent threats on servers	
Symptoms /Alerts	Possible Actions
1. Unexpected potentially legitimate traffic to suspicious internet IPs 2. Substantial scanning activity originating from a client or a server 3. Unexplained poor system performance. 4. Presence of suspicious process/files on system 5. Unexpected Surge in traffic on ports/services used by malware 6. Connections to suspicious remote systems.	29. Search if any machine infected with APT. 30. Isolate possible infected machine and install new system by restoring from last known clean backup 31. Take a copy of all logs at the perimeter level (Firewall, IPS) and traffic trends 32. Scan all the open ports which are not required and close them. 33. Apply latest security patch/update 34. Use appropriate Advanced malware and Anti APT monitoring / prevention tools / services, Threat intelligence services.
6.Ransomware Attack on servers	
Symptoms /Alerts	Possible Actions
1. A message for asking ransom is displayed along with a key 2. Identification of critical server files are being encrypted due to unknown reason.	35. Isolate system from network 36. Validate that the available backup is error free 37. Install new system by restoring from last known clean backup 38. Update the anti-virus and anti-malware and scan the system/network before resuming the operations 39. Keep file extension visible setting on. 40. Apply latest security patch/update 41. Use appropriate Advanced malware and Anti APT monitoring / prevention tools / services, Threat intelligence services.
7.Phishing email /Business email fraud/Spam	

Symptoms /Alerts	Possible Actions
1. Unexpected emails from known or unknown individuals 2. Emails that contain links and/or attachments, Phishing emails often prompt extreme feelings to push the user in the direction the malicious actor wants	42. Quarantine the malicious email from all accounts on the system 43. Under SIEM, check to see if there are any custom threat intelligence rules to add. 44. Contain. Shut down the email account so that no users can access it. 45. Examine what is in your email that got compromised
8.Identity fraud/password fraud	
Symptoms /Alerts	Possible Actions
1. Unexpected emails from known or unknown individuals asking for PII data or password change/expiry alert 2. You're notified that your information was exposed in a data breach	46. You should only open email from trusted senders 47. Verify any request for your personal information online before responding 48. Don't give out personally identifiable information 49. Minimize your risk by visiting only trusted sites. 50. Change passwords for all accounts

16. Cyber security preparedness indicators:

The adequacy of and adherence to cyber resilience framework shall be assessed and measured through development of indicators to assess the level of risk/preparedness. These indicators shall be used for comprehensive testing through independent compliance checks and audits carried out by qualified and competent professionals.

The following chart is not an exhaustive list of Key Risk Indicators on which to alert, but rather the minimum of recommended ones:

- Total Network Logs per Second
- Patch Management % / Known Vulnerabilities
- Denied FTP Requests
- Failed Remote Logins
- VPN Connections / Failed VPN Connections
- Blacklisted IP Blocked
- New Admin Credentials created
- Threshold for successive account lockouts
- ACL VLAN violations

- Changes to Group Policy
- Increase in network bandwidth
- Increase in outbound email traffic
- DNS Request anomalies

17. Mobile Financial Services:

PFL when using or intending to use Mobile Financial Services should develop a mechanism for safeguarding information assets that are used by mobile applications to provide services to customers. The technology used for mobile services should ensure confidentiality, integrity, authenticity and must provide for end-to-end encryption.

Application Security Management:

1. Ownership of the mobile application defined and documented.
2. Security risk assessment of application should be performed regularly, as per the risk framework defined considering the organisation security policy requirements.
3. Vulnerability assessment for application should be done annually.
4. Authentication mechanisms should be suitably configured to meet application security requirements which are used for the system administrators and users of application systems.

Application Change Management

1. Segregation of duties between personnel involved in the development, testing and production should be appropriately implemented.
2. The process should include the maintenance of adequate records of all changes raised. All changes should be approved by the appropriate level of management.
3. All changes are categorized and assessed for impact including the potential impact on infrastructure and security.
4. All changes should be successfully tested by IT and business users before implementation in a production environment.
5. All changes should be scheduled and communicated to those impacted before implementation.
6. All changes to production should have an associated roll-back plan.

Application Risk Assessments

A comprehensive risk assessment shall be carried for all applications prior to them being commissioned, and then annually thereafter. The assessment shall be based on parameters like the data they store / process, number of users, interface to Internet etc.

18. Continuous Surveillance

Cyber Security Operations Centre (“CSOC”) shall be setup and operationalized for testing of vulnerabilities at regular intervals of time due to the unpredictable nature of cyber-attacks, ensuring continuous surveillance and keeping itself regularly updated on the latest nature of emerging cyber threats.

The key issues which should be considered for setting up the CSOC should include:

- Proactive approach to address possible attacks.
- Proactive monitoring and management capabilities with sophisticated tools for detection, quick response and backed by data and tools for sound analytics.
- Ability to provide real-time/near-real time information on and insight into the security posture of Organisation's.
- Ability to effectively and efficiently manage security operations by preparing for and responding to cyber risks/threats, facilitate continuity and recovery.
- Ability to assess threat intelligence and proactively identify/visualize impact of threats on Organisation's.
- Methods to identify root cause of attacks, classify them into identified categories and come out with solutions to contain further attacks of similar types.
- Incident investigation, forensics and deep packet analysis need to be in place to achieve the above.
- Managed and monitored by competent and capable staff round the clock
- Level 1 monitoring by adequately trained staff working round the clock is the first step. They need to have training and product/ vendor certification to handle the tasks efficiently
- Level 2 deals with highly trained staff in specific areas of network, data security, end point security etc. to address the requirements especially while carrying out the root cause analysis as well as suitable corrective steps
- Level 3 staff are called the SOC analysts. They have profound knowledge of security, perform deep packet analysis, collection of IOC, forensic knowledge for collection of evidence, malware reverse engineering and write custom scripts whenever required.
- Dynamic Behaviour Analysis. – Preliminary static & dynamic analysis and collecting Indicators of Compromise (“IOC”)
- Analytics with good dashboard, showing the Geo-location of the IP's
- CSOC shall operate 24 x 7 x 365

19. Social Media:

- a. Social Media risks shall be included in risk assessment and a plan to treat it shall be in place
- b. Access to social media sites shall be granted strictly on a need basis.
- c. PFL shall maintain a presence on social media sites based on a need to communicate with their customers and employees.
- d. Regular monitoring of social media sites shall be undertaken to identify fake accounts created in PFL name.
- e. Only users authorized to post on behalf of PFL shall be allowed to post on the official accounts and pages.
- f. Any other PFL user posting on the account or pages shall put a disclaimer that the views expressed are his/her own and not PFL's views.
- g. Subscriptions to chat rooms, instant messaging services and or social networking sites shall be done responsibly.
- h. All users, unless authorised, shall not represent PFL or express PFL's views on a matter in chat rooms, instant messaging services or on social networking sites.
- i. Employees shall explicitly mention that no views/opinions expressed by them in chat rooms, instant messaging services and on social networking sites represent the views/opinions of PFL.
- j. Downloading and transferring of files from social networking sites or via instant messaging to and from PFL workstations shall be prohibited.
- k. Customer complaints if posted on any blog and brought to notice of PFL shall be responded to only by the users authorized to respond on social media sites.

No offensive, derogatory, defamatory, racist, sexual, religious messages or messages which would amount to libel, slander and/or annoying anyone in any manner whatsoever, shall be posted on the official account.

20. Security Vulnerability Management:

Objective: To reduce risks resulting from the exploitation of published technical vulnerabilities.

Responsibilities

- Vulnerability Assessment & Penetration Testing is responsibility of the Information Security team. It shall be conducted internally by Information Security Team or by Third party vendors under their supervision.

Periodicity

- Vulnerability assessment of the critical information systems or De-Militarized Zone (DMZ) having customer interface shall be conducted at least once in every six months.
- Penetration testing (PT) of information systems including critical systems shall be conducted at least once in 12 months.
- The Company shall conduct VA/ PT of such information systems throughout their lifecycle (pre-implementation, post implementation, after major changes, etc.).

21. Sharing of information on cyber-security incidents with RBI/ Cert-In

All types of unusual security incidents shall be reported to regulators in defined format after internal discussions.

Classification / INTERNAL

Annexure(s)

A. Cybersecurity incident reporting

1. Security Incident Reporting (SIR) to RBI

2. Cyber Security Incident Reporting (CSIR) form

Template for reporting Cyber Incidents

1. Security Incident Reporting (SIR) to RBI (within 24 hours):

2. Subsequent update(s) RBI (updates to be provided if the earlier reporting was incomplete i.e. investigation underway or new information pertaining to the incident has been discovered or as per request of RBI):

Basic Information	
1. Particulars of Reporting:	
• Name of the NBFC	
• Date and Time of Reporting to RBI, CERT-IN, other agencies (please mention separately time of reporting to each)	
• Name of Person Reporting	
• Designation/Department	
• Contact details (e.g. official email-id, telephone no, mobile no)	
2. Details of Incident:	
• Date and time of incident detection	
• Type of incidents and systems affected	
(i) <u>Outage of Critical IT system(s)</u> (e.g. CBS, Treasury Systems, Trade finance systems, Internet banking systems, ATMs, payment systems such as SWIFT, RTGS, NEFT, NACH, IMPS, etc.)	
(ii) <u>Cyber Security Incident</u> e.g. DDOS, Ransom ware/crypto ware, data breach, data destruction, web defacement, etc.)? [Please complete Annex]	
(iii) <u>Theft or Loss of Information</u> (e.g. sensitive customer or business information stolen or missing)	

or destroyed or corrupted)? (iv) <u>Outage of Infrastructure</u> (e.g. which premises-DC/Central Processing Units, branch, etc. power/utilities supply, telecommunications supply,)? (v) <u>Financial</u> (e.g. liquidity, bank run)? (vi) <u>Unavailability of Staff</u> (e.g. number and percentage on loss of staff/absence of staff from work (vii) <u>Others</u> (e.g. outsourced service providers, business partners, breach of IT Act/any other law and RBI/SEBI regulations. Etc.)?	
What actions or responses have been taken by the NBFC at the time of first reporting/till the time of subsequent reporting?	
3. Impact Assessment (examples are given but not exhaustive):	
Business impact including availability of services - Internet banking, Cash Management, Trade Finance, Branches, ATMs, Clearing and Settlement activities, etc.	
Impact on stakeholders- affected retail/corporate customers, affected participants including operator(s), settlement institution(s), business partners, and service providers, etc.	
Financial and market impact – Trading activities, transaction volumes and values, monetary losses, liquidity impact, withdrawal of funds etc.	
Regulatory and Legal impact	
4. Chronological order of events:	
Date of incident, start time and duration.	
Escalations done including approvals sought on interim measures to mitigate the event, and reasons for taking such measures	
Stakeholders informed or involved	

• Channels of communications used (e.g. email, internet, sms, press release, website notice, etc.)	
• Rationale on the decision/activation of BCP and/or DR	
5. Root Cause Analysis(RCA):	
• Factors that caused the problem/ Reasons for occurrence, Cause and effects of incident	
• Interim measures to mitigate/resolve the issue, and reasons for taking such measures, and	
• Steps identified or to be taken to address the problem in the longer term. List the remedial measures/corrections affected(one time measure) and/or corrective actions taken to prevent future occurrences of similar types of incident	
6. Date/target date of resolution _____ (DD/MM/YYYY).	

Note: All fields are **REQUIRED** to be filled unless otherwise stated.

CYBER SECURITY INCIDENT REPORTING(CSIR) FORM											
General Information		Report No:									
1. Contact Information: (Please provide if different from what is reported in Basic Information above) Name of NBFC: Name of the person reporting and Designation: Department Official Email : Telephone/Mobile : 2. Is this a ☐New incident ☐Update to reported incident? For the first update, please indicate "1. If this is an update to a reported incident, please provide the update number for this update. (X.1, X.2, X.3,X.4, etc. where X is the Report No. Update No: Click here to enter text. 3. What severity is this incident being classified as? <table border="1"> <thead> <tr> <th>Severity 1 ☐</th> <th>Severity 2 ☐</th> <th></th> </tr> </thead> <tbody> <tr> <td>Affected critical system(s)/ customer facing applications/systems, crippled Internal network or a combination of the above</td> <td>Incident occurred on system or network that could put the NBFC's network / critical system(s) or a combination of them at risk</td> <td></td> </tr> <tr> <td></td> <td></td> <td></td> </tr> </tbody> </table>			Severity 1 ☐	Severity 2 ☐		Affected critical system(s)/ customer facing applications/systems, crippled Internal network or a combination of the above	Incident occurred on system or network that could put the NBFC's network / critical system(s) or a combination of them at risk				
Severity 1 ☐	Severity 2 ☐										
Affected critical system(s)/ customer facing applications/systems, crippled Internal network or a combination of the above	Incident occurred on system or network that could put the NBFC's network / critical system(s) or a combination of them at risk										

Information about the Incident

4. Please indicate the date and time the incident was reported to the RBI. If it is also reported to Other Agencies (CERT-IN/NCIIP), Law enforcement agencies, separately indicate the date and time of such reporting.

(Please specify in Indian Local Time (+5.30 GMT))

Reported to RBI - Date: [Click here to enter a date.](#)

Reported to CERT-IN Date: [Click here to enter a date.](#)

Reported to NCIIP Date: [Click here to enter a date.](#)

Reported to ----mention the name of agency Date: [Click here to enter a date.](#)

5. Types of Threat/Incident

((Please select more than one, as applicable))

- ☐ Denial of Service (DoS) ☐ Distributed Denial of Service (DDoS)
- ☐ Virus/Worm/Trojan/Malware ☐ Intrusion/Hack/Unauthorised access
- ☐ Website Defacement ☐ Misuse of Systems/Inappropriate usage
- ☐ APT/0-day attack ☐ Spear phishing/Whaling/Phishing/Wishing/Social engineering attack
- ☐ Other: [Click here to enter text.](#)

6. Is this incident related to another incident previously reported?

Choose an item.

- If "Yes", provide more information on how both incidents are related.
[Click here to enter text.](#)
- Please provide the reference no. of the previously reported incident.
Ref no: [Click here to enter text.](#)

Incident Details

7. Please provide details of the incident in the box below.

- When was the incident first observed/sighted/detected?
[Click here to enter a date.](#)
- How was the incident first observed/sighted/detected?
[Click here to enter text.](#)
- Who observed?

8. Please provide details of the critical system(s) or network(s) that is/are impacted by this incident. Details should minimally include:

-Location, purpose of this system/ network, affected applications (including hardware manufacturer, software developer, make/ model, etc.) running on the systems/networks, etc.

[Click here to enter text.](#)

What security software installed on the system currently?

If known, any TCP or UDP ports involved in the incident.

If known, provide the affected system's IP address If known, provide the attacker's IP address

Where relevant, please indicate the Operating System of the affected critical system(s): Choose an item.

- If others, kindly state the OS: [Click here to enter text.](#)

9. What is the impact of the attack? (Tick 'one' checkbox for each column)

Customer Service Delivery	(Loss of) Sensitive Information	Public Confidence and Reputation
☐ No Impact	☐ No loss	☐ No Impact
☐ Minor Impact	☐ Minor Loss	☐ Minor Impact
☐ Major Impact	☐ Major Loss	☐ Major Impact
☐ Serious Impact	☐ Serious Loss	☐ Serious Impact
☐ Severe Impact	☐ Severe Loss	☐ Severe impact

10. Does the affected critical system(s)/ network(s) have potential impact to another critical system/critical asset(s) of the NBFC?

Choose an item.

- If "Yes", please provide more details.
[Click here to enter text.](#)

Incident Status

11. What is/are the type(s) of follow up action(s) that has/have been taken at this time?

[Click here to enter text.](#)

12. What is the current status or resolution of this incident?

Choose an item.

If it is not resolved, what is the next course of actions?

[Click here to enter text.](#)

13. What is the earliest known date of attack or compromise? (Tick 'checkbox' if unknown)

(Please specify in Indian Local Time +5.30 GMT)

Date: [Click here to enter a date.](#) Unknown: ☐

14. What is the source/cause of the incident? ('NIL' OR 'NA' if unknown)

[Click here to enter text.](#)

15. Has the incident been reported to CERT-IN/NCIIP/ any law enforcement agency/IB-CART? Choose an item.

- If "Yes", specify the agency that is being reported to.

[Click here to enter text..](#)

16. Is chain of custody maintained?

17. Has the NBFC filled chain of custody form?

18. What tools were used for collecting the evidence for the incident?

Attack Vectors

E1. Did the NBFC locate/identify IP addresses, domain names, related to the incident

Whether the Indicators of Compromise, list of IP addresses identified from the incident, involvement of the IP addresses in the incident (ex. Victim, Malware Command & Control Servers, etc.), domain names resolved, involvement of the domain names in the incident. (ex. Drive-by-download Servers, Malware Control & Command Servers, defaced website), email addresses identified and their involvement, malicious files/attachments (file name, size, MD5/SHA1 hash, etc.) etc. have been reported in IB-CART/CERT-IN/NCIIP/Law enforcement agencies

B. Abbreviations:

PFL	Poonawalla Fincorp Limited
S/MIME	Secure/Multipurpose Internet Mail Extension
TLS	Transport layer security
SSL	Secure socket layer
CA	Certificate Authorities
CCMT	Cyber Crisis Management Team
CCMP	Cyber Crisis Management Plan
DNS	Domain name space
IOC	Indicator of compromise
SOC	Security Operation Center

Classification / INTERNAL